



网络安全技术及应用

(第5版, 慕课微课版, 新形态)

贾铁军 何道敬 罗宜元 主编
古乐声 王威 张书台 副主编
王坚 陈国秦 参编

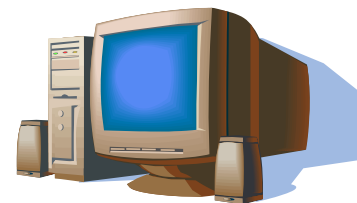
 **机械工业出版社**
CHINA MACHINE PRESS

第10章 数据库及数据安全

第10章 数据库及数据安全

第10章 目录

- 1 10.1 数据库系统安全概述
- 2 10.2 数据库及数据安全
- 3 10.3 数据库的安全防护技术
- 4 10.4 数据库备份与恢复
- 5 10.5 本章小结
- 6 10.6 实验10 SQL Server 2022安全实验



第10章 数据库及数据安全

□教学目标

- 理解数据库安全相关概念和面临的威胁
- 了解数据库系统的安全层次体系与防护
- 理解数据库主要安全策略、机制和措施
- 掌握数据库安全特性、备份和恢复技术
- 掌握 SQL Server 2022 数据库安全实验

重点

重点



10.1 数据库系统安全概述

10.1.1 数据库系统的组成

数据库技术是信息化建设和数据资源处理与共享的**关键技术**，也是各种重要数据传输和存储的**基础**。需要采取有效措施确保数据库系统的安全，实现数据的保密性、完整性和有效性。

引导案例

多家知名企业遭遇数据泄露。近几年，“数据泄露”在全世界肆虐，仅 2022 年上半年，就发生了多起世界知名企业数据泄露事件。2022 年 3 月，继英伟达（NVIDIA）75GB 的机密数据和核心源代码被泄露后，Lapsus\$勒索组织在 2022 年 3 月 4 日再次公开了韩国消费电子巨头三星电子 150GB 的机密数据和核心源代码。两次数据泄露事件之间的时间间隔还不足一周，令业界大为震动。





10.1 数据库系统安全概述

10.1.1 数据库系统的组成

在计算机中，使用数据的概念和特征描述客观世界的事物，将业务处理转化为数据处理。数据库技术就是一种最佳的数据保存及处理的方法。

数据库（**Database, DB**）是指存储在计算机中的有组织的、可共享的数据集合。数据库中的数据具有较小的冗余度、较高的数据独立性，易扩展。

数据库管理系统（**Database Management System, DBMS**）是实现数据库和数据统一管理控制的系统软件，位于用户和操作系统之间。在提供便捷的数据定义和操作的同时，保证数据的安全性、完整性。

数据库系统（**Database System, DBS**）是指具有数据处理功能特点的应用系统，通常由数据库、数据库管理系统、应用系统、数据库管理员和用户构成。

10.1 数据库系统安全概述

10.1.1 数据库系统的组成

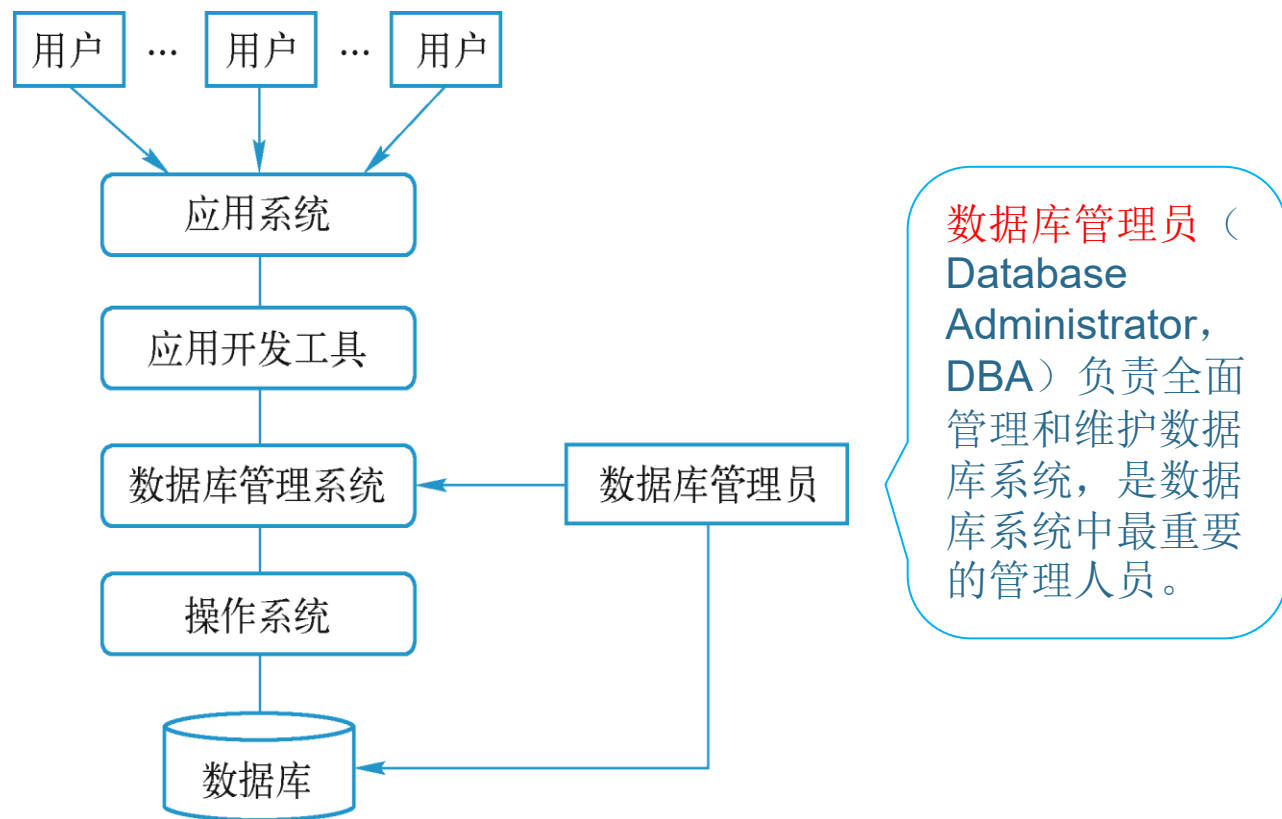


图 10-1 数据库系统的构成



10.1 数据库系统安全概述

10.1.2 数据库系统安全的概念

1. 数据库及数据安全相关概念

数据安全(Data Security)是指以保护措施确保数据的**完整性、保密性、可用性、可控性和可审查性**，防止数据被非授权访问、泄漏、更改、破坏和控制。

数据库安全 (DataBase Security) 是指采取各种安全措施对数据库及其相关文件和数据进行保护，以防止数据的泄密和破坏。主要目标是数据库的**访问控制、保密性(访问控制、用户认证、审计跟踪、数据加密等)、完整性(物理完整性、逻辑完整性和元素完整性)、可用性、可控性、可审查性等**。

数据库系统安全 (DataBase System Security) 是指为数据库系统采取的安全保护措施，防止系统软件和其中数据不遭到破坏、更改和泄漏。

注意：数据库安全的**核心和关键**是其数据安全。由于数据库存储着大量的重要信息和机密数据，且可供多用户共享，因此，必须加强对数据库访问的控制和数据的安全防护。

10.1 数据库系统安全概述

10.1.2 数据库系统安全的概念

2. 数据库安全的内涵

从系统和数据关系, 可以将**数据库安全**分为数据库应用系统安全和数据安全。

数据库应用系统安全是在**系统级**控制数据库存取和使用的机制, 包括:

- 1) 应用系统的安全管理及设置, 包括法律法规、政策制度、实体安全等。
- 2) 各种业务数据库的访问控制和权限管理。
- 3) 用户的资源限制, 包括访问、使用、存取、维护与管理等。
- 4) 系统运行安全及用户可执行的系统操作。
- 5) 对数据库系统审计管理及有效性。
- 6) 用户对象可用的存储空间及数量。

数据安全是在**对象级**控制数据库的访问、存取、加密、使用、应急处理和审计等机制, 包括用户可存取指定对象和在对象上允许具体操作类型等。



10.1 数据库系统安全概述

10.1.2 数据库系统安全的概念

3. 数据库系统的主要安全问题

(1) 法律法规、社会伦理道德和宣传教育滞后或不完善等。

(2) 现行的政策、规章制度、人为错误及管理出现的安全问题。

(3) 硬件系统或控制管理问题。如 **CPU** 是否具备安全性方面的特性。

(4) 实体安全。如服务器、主机外设、网络设备及运行环境等安全。

(5) 操作系统及**DBMS**的漏洞与风险等安全性问题。

(6) 可操作性问题。采用的密码方案所涉及的密码自身的安全性问题。

(7) **DBS**本身的漏洞、缺陷和隐患带来的安全性问题。

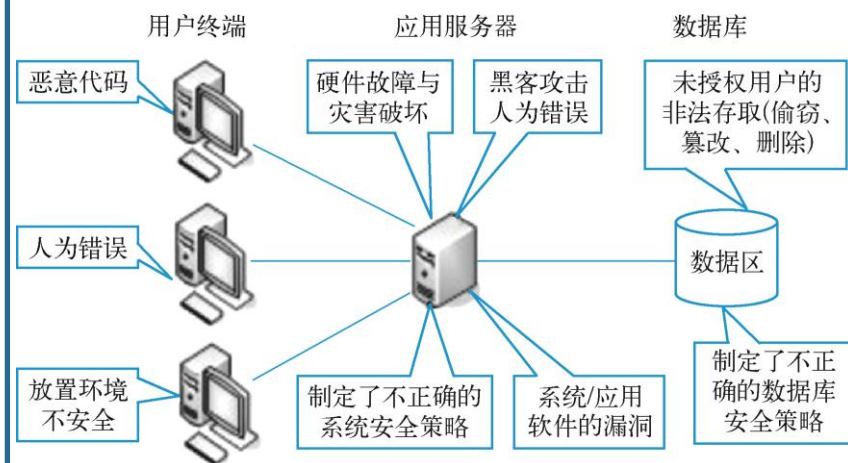


图10-2 数据库系统面临的安全问题



10.1 数据库系统安全概述

10.1.3 数据库系统的安全性需求

案例10-1 公司员工泄露机密数据。2022年4月，某公司员工泄密事件法院裁决公示，该员工被指在离职后利用公司内部 ERP 系统漏洞多次越权访问机密数据并牟利，2016—2018年间通过邮件等方式将公司多个供应商共 1183个物料的采购价格数据发送给相关企业，从而帮助其在公司的招标项目中提高中标率。

企业资源
计划系统



10.1 数据库系统安全概述

10.1.3 数据库系统的安全性需求

1. 数据库的安全威胁

数据库的安全威胁主要有数据篡改、数据损坏和数据窃取。

1) 数据篡改。数据篡改是对数据库中的数据未经授权就进行修改，破坏数据的真实性，如修改成绩、伪造发货单等。这类修改是一个潜在的问题，表面上看来是没有任何迹象的，在造成影响之前，数据库管理者一般很难发现。数据篡改一般是基于以下的**动机**：个人利益驱动、隐匿或毁坏证据、恶作剧或开玩笑、无意识的修改或用户误操作等。

2) 数据损坏。数据库中的表、数据甚至整个数据库都有可能被删除、移动或破坏，使得数据库的内容**不可用**。数据损坏的**原因**主要是破坏、恶作剧、病毒等。



10.1 数据库系统安全概述

10.1.3 数据库系统的安全性需求

1. 数据库的安全威胁

3) 数据窃取。通过对敏感数据的未授权访问来实现数据窃取，可能是将数据复制到其他介质上，或是输出成可直接或间接读取的资料(如打印)，也可能是通过网络连接对敏感数据进行未授权的访问或处理。数据窃取的主要原因有：一些数据可能比想象的还重要；不满的员工或辞职的员工；工商业间谍等。数据窃取均来自于对数据库的直接或间接攻击，**直接攻击**是通过查询以得到几个记录来直接搜索并确定敏感字段的值，**间接攻击**则是依据一种或多种统计值推断出结果。

10.1 数据库系统安全概述

10.1.3 数据库系统的安全性需求

2. 数据库系统的安全性要求

数据库系统的安全性需求包括数据库的保密性、完整性、可用性、可控性、可审计性、存取控制与用户认证等。

数据库系统通常是在操作系统的控制之下运行的，可以利用操作系统已经提供的安全措施来加强数据库系统的安全性。与操作系统相比，不同之处在于操作系统中的对象为文件，而数据库系统中要求有更加**精确的数据粒度**，如要求精确到数据库的表级、域级，直到行级、元素级等。操作系统并不关心相关的数据对象的语义及其相互关系，而数据库系统则必须**重视数据的语义**。

1) 保密性。是指保护数据库中的**数据不被泄露和未授权的获取**。维护数据库系统保密性的**方法**主要有：主体身份识别和确认、访问操作的鉴别和控制、数据信息的加密、审计和跟踪。

2) 完整性。包括**数据库物理完整性、数据库逻辑完整性和数据库数据元素取值的准确性和正确性**。例如，数据库中的数据不会被无意或恶意地插入、破坏和删除；保证数据的正确性、一致性和相容性；保证合法用户得到与现实世界信息语义和信息产生过程相一致的数据。为了保证数据库中每个元素的完整性，**DBMS** 采用**3种方法**进行维护：字段有效性检查、通过访问控制维护数据的完整性和一致性、维护数据库的更新日志以利于故障恢复。

10.1 数据库系统安全概述

10.1.3 数据库系统的安全性需求

2. 数据库系统的安全性要求

3) 可用性。是指确保数据库中的数据不因人为或自然的原因对授权用户不可用。某些运行关键业务的数据库系统应保证全天候的可用性。

4) 可控性。是指可以控制授权范围内的信息流向及行为，对数据的传输及内容具有控制能力。是对数据操作和数据库系统事件的监控属性，也指对违背保密性、完整性、可用性的事件具有监控、记录和事后追查的属性。

5) 可审计性。是指对数据库系统的各种安全事件做好检查和跟踪记录，以便对出现的安全问题提供调查的依据和手段。审计的结果通常可以作为追究责任和进一步改进系统的参考。

6) 存取控制。只允许授权用户访问被授权访问的数据，不同的用户有不同的访问模式如读或写。即只对授权的合法用户给予访问权限，令所有未正常授权的人员均无法接近数据，即防止和杜绝非授权的数据访问，无论是窃取还是破坏。

7) 用户认证。确保每个用户都能够被正确识别，避免非法用户的入侵，既便于审计追踪，也能限制对特定数据的访问。**DBMS** 通常要求严格的用户认证，指定应该允许哪些用户访问哪些数据，这些数据可以是字段、记录甚至是元素级的。

10.1 数据库系统安全概述

10.1.3 数据库系统的安全性需求

3. 数据库系统安全标准

1985年，美国国防部(DoD)正式颁布《DoD 可信计算机系统评估准则》(简称TCSEC或DoD85)，从D(最小保护)到 A1(验证设计)共划分了7个安全级别。

1996年，《信息技术安全评估通用准则》即CC 1.0发布。

1999年，CC 2.1 版被 ISO 采用为国际标准。

2001年，CC 2.1被我国采用为国家标准 GB/T 18336 系列。

2019年，我国的《信息安全技术—数据库管理系统安全技术要求》(GB/T20273-2019)发布，从评估对象描述、安全问题定义、安全目的、安全要求、基本原理多个方面进行说明，列出了 DBMS 评估保障级(EAL)2、3 和 4的要求。

10.1 数据库系统安全概述

10.1.3 数据库系统的安全性需求

表 10-1 信息技术安全评估通用准则 CC 安全级别

评估保障级	定义
EAL1	系统功能测试
EAL2	系统结构测试
EAL3	系统地测试和检查
EAL4	系统地设计、测试和复查
EAL5	半形式化设计和测试
EAL6	半形式化验证的设计和测试
EAL7	形式化验证的设计和测试

10.1 数据库系统安全概述

10.1.4 数据库系统的安全框架

1. 数据库系统的安全框架

数据库系统的安全框架可以划分为**3个层次**：网络系统层、宿主操作系统层、数据库管理系统层。这3个层次构筑成数据库系统的安全体系，与数据安全的关系是逐步紧密的，防范的重要性也逐层加强，从外到内、由表及里保证数据的安全。

(1) 网络系统层

数据库系统安全依赖于网络系统的安全。随着Internet的快速发展和广泛应用，越来越多的企业将其核心业务转向互联网，各种基于网络的数据库应用系统也得到了广泛应用，面向网络用户提供各种信息服务。在新的行业背景下，网络系统是数据库应用的**重要基础和外部环境**，数据库系统要发挥其强大作用离不开网络系统的支持，如数据库系统的异地用户、分布式用户也要通过网络才能访问数据库。

外部入侵事件通常都是从入侵网络系统开始的，网络系统的安全就成为数据库安全的第一道屏障。网络系统的开放式环境使其面临着诸多安全威胁，如欺骗、重放、报文篡改、后门、木马、拒绝服务、病毒等，必须采取有效措施来保障网络系统的安全。网络系统层的安全防范技术有很多种，主要包括防火墙、入侵检测、入侵防御等。

10.1 数据库系统安全概述

10.1.4 数据库系统的安全框架

1. 数据库系统的安全框架

(2) 宿主操作系统层

操作系统是数据库系统的**运行平台**，可为数据库系统提供一定程度的安全保护。目前，主流操作系统平台安全级别较低，通常为C1或C2级，需要采用相关安全技术进行宿主操作系统的安全防御，主要**包括**操作系统安全策略、安全管理策略、数据安全等方面。

1) **操作系统安全策略**。主要用于配置本地计算机的安全设置，包括密码策略、账户锁定策略、审核策略、IP 安全策略、用户权利指派、加密数据的恢复代理以及其他安全选项。具体体现在用户账户、口令、访问权限、审计等方面。

2) **安全管理策略**。安全管理策略是指网络管理员对系统实施安全管理所采取的方法及措施、针对不同的操作系统和网络环境，需要采取的安全管理策略不尽相同，但是，其核心是保证服务器的安全和分配好各类用户的权限。

3) **数据安全**。主要包括数据加密技术、数据备份、数据存储及传输安全等。可以采用Kerberos 认证、IPSec、SSL、VPN 等多种技术。

10.1 数据库系统安全概述

10.1.4 数据库系统的安全框架

1. 数据库系统的安全框架

(3) 数据库管理系统层

数据库系统的安全性很大程度上依赖于 DBMS。目前，关系数据库管理系统是市场主流，但其安全性较弱，导致数据库系统的安全性存在一定风险和威胁。

由于数据库系统在操作系统下都是以文件形式进行管理的，因此入侵者可以直接利用操作系统的漏洞窃取数据库文件，或者直接利用 OS 工具来非法伪造、篡改数据库文件内容。这种隐患一般数据库用户难以察觉。在前面两个层次已经被突破的情况下，若希望保障数据库系统的安全，就要求数据库管理系统必须有一套强有力的安全机制。有效方法之一是通过数据库管理系统对数据库文件进行加密处理，使得数据难以被破译和阅读。可以在3个不同层次对数据库数据进行加密。

1) 操作系统层加密。操作系统作为数据库系统的运行平台管理着数据库的各种文件，并可通过加密系统对数据库文件进行加密操作。由于此层无法辨认数据库文件中的数据关系，使得难以对密钥进行管理和使用，因此，对大型数据库在操作系统层无法实现对数据库文件的加密。

10.1 数据库系统安全概述

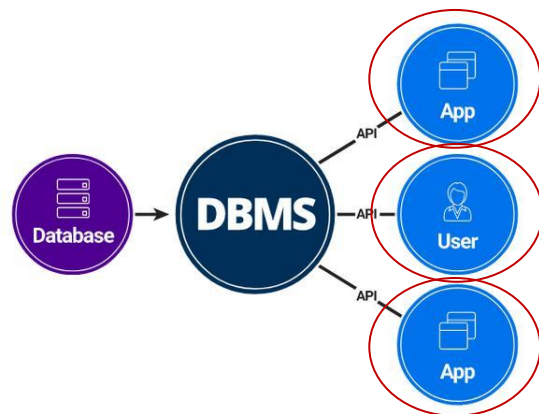
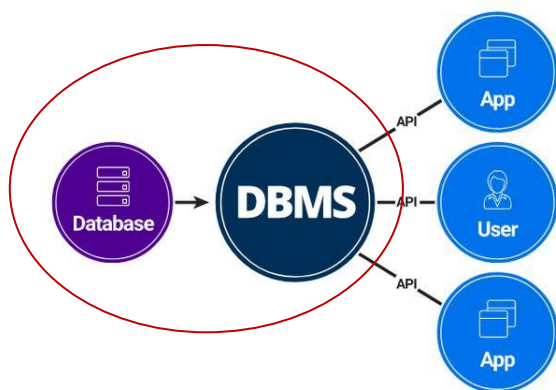
10.1.4 数据库系统的安全框架

1. 数据库系统的安全框架

(3) 数据库管理系统层

2) DBMS 内核层加密。主要是指数据在物理存取之前完成加/解密工作。其加密方式的优点是加密功能强，且基本不影响 DBMS 的功能，可实现加密功能与 DBMS 之间的无缝耦合。其缺点是加密运算在服务器端进行，加重了其负载，且 DBMS 和加密器之间的接口需要 DBMS 开发商的支持。

3) DBMS 外层加密。在实际应用中，可将数据库加密系统做成 DBMS 的一个外层工具，根据加密要求自动完成对数据库数据的加/解密处理。



10.1 数据库系统安全概述

10.1.4 数据库系统的安全框架

2. 数据库安全的层次体系结构

(1) 物理层：计算机网络系统的最外层最容易受到攻击和破坏，主要侧重保护计算机网络系统、网络链路及其网络节点等**物理(实体)安全**。

(2) 网络层：其安全性和物理层安全性一样极为重要，由于所有网络数据库系统都允许通过网络进行**远程访问**，因此，更需要做好安全保障。

(3) 操作系统层：操作系统在数据库系统中，**与 DBMS 交互并协助控制管理数据库**，其安全漏洞和隐患成为对**数据库攻击和非授权访问**的最大威胁与隐患。



10.1 数据库系统安全概述

10.1.4 数据库系统的安全框架

2. 数据库安全的层次体系结构

(4) 数据库系统层：主要包括 **DBMS 和各种业务数据库等**，数据库存储着重要及敏感程度不同的各种业务数据，并通过网络为不同授权用户所共享，数据库系统必须采取**授权限制、访问控制、加密和审计**等安全措施。

(5) 应用层：也称为用户层，主要侧重用户**权限管理、身份认证及访问控制**等，防范非授权用户以各种方式对数据库及数据的攻击和非法访问，也包括各种越权访问等。

为了确保数据库安全，必须在**所有层次上**进行安全性保护措施。若较低层次上安全性存在缺陷，则严格的高层安全性措施也可能被绕过而出现安全问题。

10.1 数据库系统安全概述

10.1.4 数据库系统的安全框架

3. 可信DBMS体系结构

(1) **TCB子集DBMS**体系结构。**可信计算基(Trusted Computing Base, TCB)**是指计算机内保护装置的总体，包括硬件、固件、软件和负责执行安全策略的组合体。利用位于**DBMS**外部的**TCB**，如可信操作系统或可信网络，执行安全机制的可信计算基子集**DBMS**，以及对数据库客体的强制访问控制。该体系将多级数据库客体按**安全属性**分解为单级断片(同一断片的数据库客体属性相同)，分别进行**物理隔离**存储入操作系统客体中。各操作系统客体的安全属性就是存储在其中的数据库客体的安全属性，**TCB**可对此隔离的单级客体实施强制存取控制。

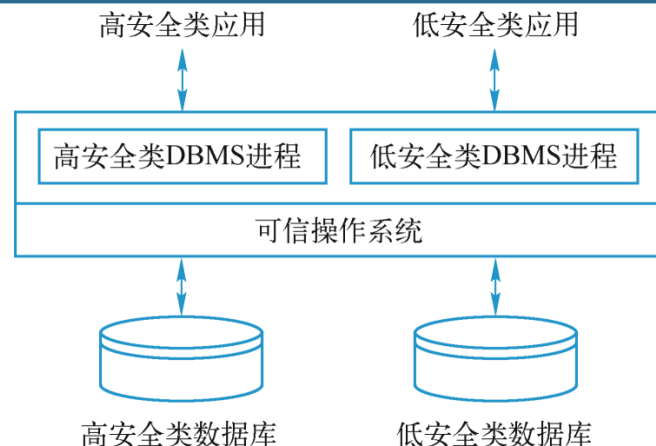


图10-3 TCB子集DBMS体系结构

10.1 数据库系统安全概述

10.1.4 数据库系统的安全框架

3. 可信DBMS体系结构

该体系的最简单方案是将**多级数据库分解为单级元素**，安全属性相同的元素存在一个单级操作系统客体中。使用时先初始化一个运行于用户安全级的 DBMS 进程，通过操作系统实施的强制访问控制策略，DBMS 仅访问不超过该级别的客体。此后，DBMS 从同一个关系中将元素连接起来，重构成多级元组，返回给用户，如图 10-3所示。

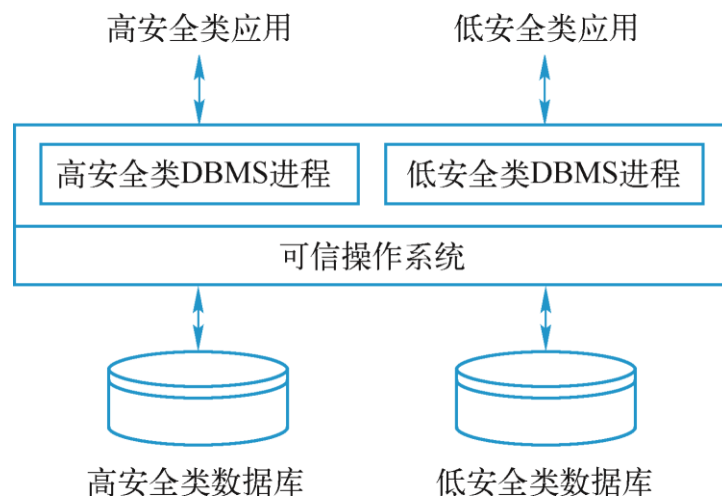


图10-3 TCB子集DBMS体系结构

10.1 数据库系统安全概述

10.1.4 数据库系统的安全框架

3. 可信DBMS体系结构

(2) **可信主体DBMS**体系结构。执行强制访问控制。按**逻辑结构**分解多级数据库，并存储在几个单级操作系统客体中。各种客体可同时存储多种级别的数据库客体(如数据库、关系、视图、元组或元素)，并且与其中最高级别数据库客体的敏感性级别相同。该体系结构的一种简单方案如图 10-4 所示，**DBMS** 软件仍在可信操作系统上运行，所有对数据库的访问都须经由可信 **DBMS**。

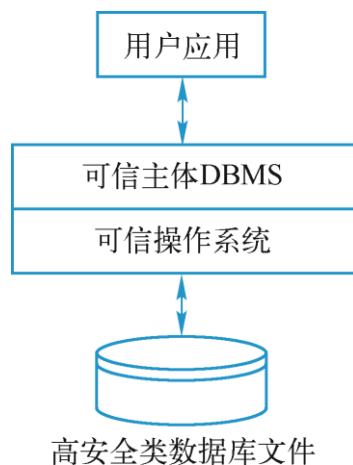


图10-4 可信主体DBMS体系结构

10.2 数据库及数据安全

10.2.1 数据库的安全性

案例10-2

数据库暴露数量大，数据泄露损失严重。 据

Group-IB数据显示，2021年共有30.8万个包含敏感信息的数据库被暴露在互联网上，2022年第一季度新发现的公开数据库就多达9万个，增速迅猛；2021年超过 30%（约 93600个）的暴露数据库位于美国，中国暴露量位列第二。据 IBM中国调研发现，恶意数据泄露给调研中的受访企业带来平均 445万美元的损失，比系统故障和人为错误等意外原因导致的数据泄露高出 100多万美元。

数据库的安全特性主要包括：**数据库及数据的独立性、安全性、完整性、并发控制、故障恢复**等几个方面。其中，数据独立性包括**物理独立性和逻辑独立性**。物理独立性是指用户的应用程序与存储在数据库中的数据是相互独立的。逻辑独立性是指用户的应用程序与数据库逻辑结构相互独立，两种数据独立性都由 **DBMS** 实现。



10.2 数据库及数据安全

10.2.1 数据库的安全性

1. 数据库的安全性要求

数据库安全的**核心和关键**是数据安全。网络安全的最终目标是实现**数据(信息)安全**的属性特征(保密性、完整性、可用性、可控性和可审查性), 其中**保密性、完整性、可用性**是数据(信息)安全的**最基本要求**, 也是数据库的**基本安全目标**。

(1) 保密性

数据的保密性是指**不允许未经授权或越权的用户存取或访问数据**。可**采取**对用户的标识与鉴别、存取控制、数据库加密、审计、备份与恢复、推理控制与隐私保护等措施防范。



10.2 数据库及数据安全

10.2.1 数据库的安全性

(1) 保密性

①用户标识与鉴别：

由于数据库用户的安全等级不同，需要分配不同权限，数据库系统必须建立严格的**用户认证机制**。**DBMS** 先对用户身份进行**标识和鉴别授权**，且通过审计保留追究用户行为的权利。

②存取控制：

主要是确保用户对数据库的操作只能在**授权**情况下进行。



10.2 数据库及数据安全

10.2.1 数据库的安全性

(1) 保密性

③数据库加密:

数据库以文件形式通过操作系统进行管理，黑客可直接利用操作系统的漏洞窥视、窃取或篡改数据库文件。数据库的保密既包括**传输**中采用加密和访问控制，也包括对**存储**的敏感数据进行加密。

数据库加密技术的**功能和特性**主要包括6个:身份认证、通信加密与完整性保护、数据库中数据存储的加密与完整性保护、数据库加密设置、多级密钥管理模式和安全备份。对数据进行加密的**方式**主要有3种:系统中加密、服务器端加密和客户端加密。

10.2 数据库及数据安全

10.2.1 数据库的安全性

(1) 保密性

④ 审计：

审计是监视并通过审计系统记录用户对数据库各种操作的机制。审计系统记录用户对数据库的所有操作，并且存入指定日志，事后可利用这些信息追溯数据库现状及相关事件，是提供分析攻击者线索的重要依据。

DBMS 的审计主要分为 4 种：语句审计、特权审计、模式对象审计和资源审计。**语句审计**是指监视一个或多个特定用户或所有用户提交的 **SQL** 语句；**特权审计**是指监视一个或多个特定用户或所有用户使用的系统特权；**模式对象审计**是指监视一个模式中在一个或多个对象上发生的行为；**资源审计**是指监视分配给每个用户的系统资源。



10.2 数据库及数据安全

10.2.1 数据库的安全性

(1) 保密性

⑤ 备份与恢复：

为了防止意外事故，需要及时进行**数据备份**，而且当系统发生故障后可利用数据备份**快速恢复**，并保持数据的**完整性和一致性**。

⑥ 推理控制与隐私保护：

数据库安全中的推理是指用户**根据低密级的数据和模式的完整性约束推导出高密级的数据**，造成未经授权的信息泄密，其推理路径称为“推理通道”。



10.2 数据库及数据安全

10.2.1 数据库的安全性

假设有一个的医院数据库，

挂号记录表（低密级）：患者姓名、挂号科室和挂号时间等信息。

诊断结果表（高密级）：患者的详细诊断信息。

数据库的设计中存在一些完整性约束，比如规定每个患者在某个科室挂号后都会有一个对应的诊断结果记录。同时，“挂号记录”表中的患者姓名与“诊断结果”表中的患者姓名有外键关联。

某医院的普通文员可以查看“挂号记录”表中的所有信息。他发现最近一段时间，某知名人士频繁在医院的心脏科挂号。于是，他根据这个低密级的挂号信息，再结合对医院一般诊疗流程的了解（即挂了心脏科号通常是为了检查心脏相关疾病），以及数据库中关于挂号和诊断结果之间关联的完整性约束（知道每个挂号的患者都会有一个诊断结果），推断出这个知名人士很可能患有心脏方面的疾病，这就从低密级的挂号数据推导出了高密级的诊断相关的敏感信息，形成了一个推理通道，导致了高密级数据的泄密风险。

10.2 数据库及数据安全

(2) 完整性

①物理完整性。是指保证数据库中的数据不受物理故障(如硬件故障或断电等)的影响,并可设法在灾难性毁坏时重建和恢复数据库。

②逻辑完整性。是指对数据库逻辑结构的保护,包括数据语义与操作完整性。前者主要指数据存取在逻辑上满足完整性约束,后者主要指在并发事务处理过程中保证数据的逻辑一致性。

(3) 可用性

数据的可用性是指在授权用户对数据库中的数据进行正常操作的同时,保证系统的运行效率,并为用户提供便利的人机交互。

注意: 实际上,有时数据保密性和可用性之间可能存在一定冲突。对数据库加密必然会带来数据存储与索引、密钥分配和管理等问题,同时加密也会极大地降低数据访问与运行效率。

10.2 数据库及数据安全

10.2.1 数据库的安全性

2. 数据库的安全性措施

数据库常用的**三种安全性措施**：用户的身份认证、数据库的使用权限管理和数据库中对象的使用权限管理。**数据库系统安全控制模式**如图10-5所示。

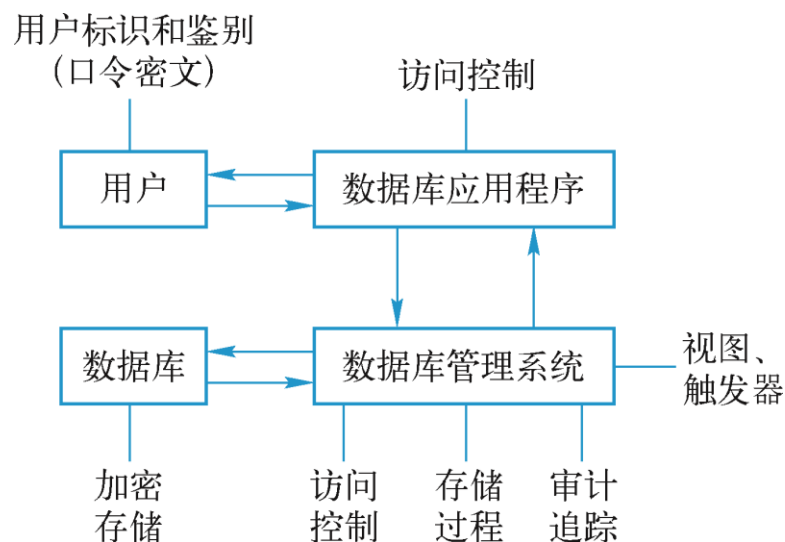


图10-5 数据库系统安全控制模式

10.2 数据库及数据安全

10.2.1 数据库的安全性

2. 数据库的安全性措施

(1) **身份认证**是在网络系统中确认操作用户身份的过程。包括用户与主机间的认证和主机与主机之间的认证。主要通过用户对用户所知道的物件或信息,如口令、密码、证件、智能卡(如信用卡)等;用户所具有的生物特征:指纹、声音、视网膜、签字、笔迹等进行认证、身份认证管理是对此相关方面的管理。

(2) **权限管理**主要体现在授权和角色管理。

1) **授权**。**DBMS** 提供了功能强大的授权机制,可给用户授予各种不同对象(表、视图、存储过程等)的不同使用权限,如查询、增删改等。

2) **角色**。角色指一组相关权限的集合。是被命名的一组与数据库操作相关的权限,即可为一组相同权限的用户创建一个角色。使用角色管理数据库权限,便于简化授权的过程。

10.2 数据库及数据安全

10.2.1 数据库的安全性

知识拓展：权限管理常用操作语句

(1) 创建用户 (**CREATE USER**)

```
CREATE USER 'username'@'localhost' IDENTIFIED BY  
'password';
```

(2) 授予权限 (**GRANT**)

```
GRANT SELECT, INSERT ON database_name.table_name  
TO 'username'@'localhost';
```

(3) 查询权限 (**SHOW GRANTS**)

```
SHOW GRANTS FOR 'username'@'localhost';
```

不过在 SQL Server 中，一般通过查询系统视图如 `sys.database_permissions` 等来查看权限相关信息，例如 ``SELECT * FROM sys.database_permissions;``。

10.2 数据库及数据安全

10.2.1 数据库的安全性

2. 数据库的安全性措施

(3) **视图**提供了一种安全简便访问数据的方法，在授予用户对特定视图的访问权限时，该权限只能用于在该视图中定义的数据项，而不能用于视图对应的完整基本表。

(4) **审计管理**

审计是记录审查数据库操作和事件的过程。通常，审计记录会记载用户所用的系统权限、频率、登录的用户数、会话平均持续时间、操作命令，以及其他有关操作和事件。通过审计功能可将用户对数据库的所有操作自动进行记录，并存入审计日志中。



10.2 数据库及数据安全

10.2.2 数据库及数据的完整性

1. 数据库完整性

数据库完整性（**Database Integrity**）是指DB中**数据**的**正确性和相容性**。实际上以各种**完整性约束**做保证，数据库完整性设计是数据库完整性约束的设计。可以通过 **DBMS** 或应用程序实现数据库完整性约束，基于 **DBMS** 的完整性约束以模式的一部分存入数据库中。**数据库完整性对于数据库应用系统至关重要**，其主要作用体现在**4**个方面：

10.2 数据库及数据安全

10.2.2 数据库及数据的完整性

1. 数据库完整性

1) 防止合法用户向数据库中添加不合语义的数据。

2) 利用基于**DBMS**的完整性控制机制实现业务规则,易于定义和理解,且可降低应用程序复杂性,提高运行效率。同时,基于**DBMS**的完整性控制机制在于集中管理,比应用程序更容易实现数据库的完整性。

3) 合理的数据库完整性设计,可协调兼顾数据库的完整性和系统效能。如加载大量数据时,只在加载之前临时使基于**DBMS**的数据库完整性约束失效,完成加载后再使其生效,这样做既不影响数据加载的效率又能保证数据库的完整性。

4) 在应用软件的功能测试中,有助于发现软件错误。

DB完整性约束可分列级静态约束、元组级静态约束、关系级静态约束、列级动态为六类:约束、元组级动态约束、关系级动态约束。动态约束常由应用软件实现,不同**DBMS**支持的数据库完整性基本相同。

10.2 数据库及数据安全

10.2.2 数据库及数据的完整性

2. 数据完整性

数据完整性(Data Integrity)是指数据的**正确性、有效性和一致性**。其中，**正确性**是指数据的输入值与数据表对应域的类型相同；**有效性**是指数据库中的理论数值满足现实应用中对该数值段的约束；**一致性**是指不同用户使用的同一数据完全相同。数据完整性可防止数据库中存在**不符合语义规定的**数据，并防止**因错误数据的输入/输出造成无效操作或产生错误**。数据库中存储的所有数据都需要处于正确状态，若数据库中存在不正确的数据值，则称该数据库已失去数据完整性。

10.2 数据库及数据安全

10.2.2 数据库及数据的完整性

2. 数据完整性

数据完整性分为以下4类：

(1) **实体完整性**：明确规定数据表的**每一行在表中是唯一的实体**。如表中定义的UNIQUE PRIMARYKEY 和 IDENTITY 约束。自动生成递增数字

(2) **域完整性**：指数据库表中的**列必须满足某种特定的数据类型或约束**。其中，约束又包括取值范围、精度等规定。如表中的 CHECK、FOREIGN KEY 约束和DEFAULT、NOT NULL等要求。数值约束条件

(3) **参照完整性**：指任何两表的**主键和外键的数据要对应一致**，确保表之间数据的一致性，以防止数据丢失或造成混乱。主要作用为：禁止向从表中插入包含主表中不存在键的数据行；禁止可导致从表中的相应值孤立的主表中的外键值改变；禁止删除在从表中的有对应记录的主表记录。

(4) **用户定义完整性**。是针对某个特定关系数据库的约束条件，可以反映某一具体应用所涉及的数据必须满足的语义要求。SQLServer提供了定义和检验这类完整性的机制，以便用统一的系统方法进行处理，而不是用应用程序承担此功能。其他完整性类型都**支持用户定义的完整性**。**数据库采用多种方法保证数据完整性**，包括外键、约束、规则和触发器。

10.2 数据库及数据安全

10.2.3 数据库的并发控制

案例10-3

网上购物时，客户 C1 和 C2 均对商品 G 进行下单。客户 C1 下单时，先读出商品 G 的库存为 n 。同一时刻（也可以不是同时刻，只要在客户 C1 更新数据之前即可），客户 C2 也读出了商品 G 的库存为 n 。客户 C1 下单后，商品 G 库存-1，写入数据库，此时商品 G 的库存为 $n-1$ ；客户 C2 下单后，商品 G 库存-1，写入数据库，此时商品 G 的库存为 $n-1$ （因为之前读出的商品 G 库存为 n ）。商品 G 的库存显然是不正确的，实际库存应更新为 $n-2$ 。原因是 C2 的修改覆盖了 C1 的修改。

上述这种情况称为**数据的不一致性**，主要原因是**并发**操作。是由于处理程序工作区中的数据与数据库中的数据不一致而造成的。若处理程序不对数据库中的数据进行修改，则不会造成不一致。另外，若没有并行操作发生，则这种临时的不一致也不会出现问题。

10.2 数据库及数据安全

10.2.3 数据库的并发控制

通常，对于数据**不一致性**分类，包括4种：

1) **丢失或覆盖更新**。当两个或多个事务选择同一数据，并且基于最初选定的值更新该数据时，会发生丢失更新问题，如上述网上购物库存问题。

2) **不可重复读**。在一个事务范围内，两个相同查询将返回不同数据，这是由于查询注意到其他提交事务的修改而引起的。

电商库存查询场景：用户 A 在电商平台上打开商品详情页面，页面显示某商品库存为 100 个。这是事务 1 的第一次查询操作，记录了库存数量。此时，事务 2 是平台工作人员进行补货操作，将该商品库存增加 50 个，并提交事务。用户 A 在浏览商品页面的过程中，再次点击刷新按钮查看库存，此时事务 1 进行第二次查询，结果显示库存为 150 个。在同一个事务 1 的范围内，两次相同的查询返回了不同的数据，这就是不可重复读问题，因为事务 1 注意到事务 2 提交的修改。

10.2 数据库及数据安全

10.2.3 数据库的并发控制

3) **读脏数据**。指一个事务读取另一个未提交的并事务所写的数据库。当第二个事务选择其他事务正在更新的行时，会发生未确认的相关性问题。第二个事务正在读取的数据还没有确认，并可能由更新此行的事务所更改。

医院挂号系统场景：患者小明在医院挂号系统中挂号，事务 1 是患者小明的挂号操作，系统先将该患者的挂号信息写入数据库，但还未提交事务（因为可能还需要结合支付环节等其他操作一起提交）。此时，事务 2 是医院分诊台查看挂号信息以便安排出诊医生的事务。事务 2 读取了患者小明的挂号信息（这个信息所属事务 1 还未提交）。之后事务 1 因为某种原因（比如患者取消挂号）回滚了事务，那么分诊台根据读取到的这个脏数据进行的后续安排（如提前预留了诊室等）就都是基于错误信息的操作，导致了读脏数据带来的不一致性。

10.2 数据库及数据安全

10.2.3 数据库的并发控制

4) **破坏性的数据定义语言(DDL)操作**。当某一用户修改一个表的数据时，另一用户同时更改或删除该表。

企业资源规划（ERP）系统场景：在一个企业的 ERP 系统中，有一个“员工信息表”，该表存储员工的基本信息如姓名、年龄、职位等。事务 1 是人力资源部门查询员工信息表，准备统计不同职位的员工数量用于生成报表。同时，事务 2 是系统管理员对数据库进行结构优化，执行了删除“员工信息表”中“年龄”字段这一操作（可能是认为该字段以后不会再用或者要重新设计）。这就导致事务 1 在查询过程中，该表的结构被破坏，事务 1 无法正常获取到完整准确的员工信息，出现了破坏性的操作导致的数据不一致性。

10.2 数据库及数据安全

10.2.3 数据库的并发控制

2. 并发控制及事务

并发事件指在实现多用户共享数据时，有多个用户**同时存取**数据的事件。对并发事件的有效控制称为**并发控制**。并发控制是确保及时纠正由并发操作导致的错误的一种机制，是当多个用户同时更新运行时，用于保护数据库完整性的技术。

事务（**Transaction**）是并发控制的基本单位，是用户定义的一组操作序列，是数据库的逻辑工作单位，一个事务可以是一条或一组**SQL**语句。事务的开始或结束都可以由用户显式控制，若用户无显式地定义事务，则由数据库系统按默认规定自动划分事务。

事务通常是以 **BEGIN TRANSACTION** 开始，以提交 **COMMIT** 或回滚(退回)**ROLLBACK** 结束。

10.2 数据库及数据安全

10.2.3 数据库的并发控制

2. 并发控制及事务

事务属性(ACID 特性)包括:

- 1) **原子性(Atomicity)**。保证事务中的一组操作不可再分，即这些操作是一个整体“要么都做，要么都不做”。
- 2) **一致性(Consistency)**。事务从一个一致状态转变到另一个一致状态。如转账操作中，各账户金额必须平衡，一致性与原子性密切相关。
- 3) **隔离性(Isolation)**。指一个事务的执行不能被其他事务干扰。一个事务的操作及使用的数据与并发的其他事务互相独立、互不影响。
- 4) **持久性(Durability)**。事务一旦提交，对数据库所做的操作是不变的，即使发生故障也不会对其有任何影响。

10.2 数据库及数据安全

10.2.3 数据库的并发控制

3. 并发控制的具体措施

数据库管理系统 **DBMS** 对**并发控制**的**任务**是：确保多个事务同时存取同一数据时，保持事务的**隔离性与统一性**以及数据库的**统一性**，常用方法是对数据进行**封锁**。

封锁(Locking)是事务**T** 在对某个数据对象(如表、记录等)操作之前，先向系统发出请求，对其加锁。加锁后事务**T** 就对该数据对象有了一定的控制，在事务 **T** 释放该锁之前，其他事务不可更新此数据对象。

常用的封锁有两种：**X锁(排他锁、写锁)**和**S锁(只读锁、共享锁)**。**X**锁禁止资源共享，若事务以此方式封锁资源，则只有此事务可更改该资源，直至释放。**S**锁允许相关资源共享，多个用户可同时读取同一数据，几个事务可在同一共享资源上再加**S**锁。**S**锁比**X**锁具有更高的数据并行性。

注意:在多用户系统中使用封锁后可能会出现**死锁**情况，引起一些事务难以正常进行当多个用户彼此等待所封锁的数据时可能就会出现死锁现象。



10.2 数据库及数据安全

10.2.3 数据库的并发控制

4. 故障恢复

由数据库管理系统(DBMS)提供的机制和多种方法,可及时发现故障和修复故障,从而防止数据被破坏。数据库系统可以尽快恢复数据库系统运行时出现的故障,可能是物理上或逻辑上的错误,如对系统的误操作造成的数据错误等。

10.3 数据库的安全防护技术

10.3.1 数据库安全防护及控制

数据共享是数据库的一大特点，同时也带来了数据库的安全性问题，数据库系统中的数据共享不能是无条件的共享。数据库安全防护的**目的**是防止不合法使用所造成的数据泄露、更改或破坏。安全防护措施是否有效是数据库系统**主要的性能指标之一**。

案例10-4

首例数据合规不起诉案件公开听证会举行。

2022年4月28日，上海市普陀区检察院对某网络科技有限公司、陈某某等人非法获取计算机信息系统数据案开展不起诉公开听证。

2019—2020年，该公司在未经授权许可的情况下，为运营需要，由陈某某指挥多名技术人员，通过数据爬虫技术，非法获取某外卖平台的数据，造成该平台直接经济损失 4万余元。检察院建议设置专门的数据合规管理部门，消除内部管理盲区，建立数据分级分类管理制度及员工数据安全管理制度，提高数据合规风险识别及应对能力。

10.3 数据库的安全防护技术

10.3.1 数据库安全防护及控制

1. 数据库安全防护模型

数据库面临诸多不安全因素，如非授权用户的存取和破坏、重要或敏感数据的泄露、安全环境的脆弱性等。数据库的**安全防护模型**如图 10-6 所示。

数据库安全防护模型的**原理**为：首先，根据用户标识鉴别用户身份，合法用户才准许进入系统；其次，对数据库管理系统进行存取控制，只允许用户执行合法操作；第三，加强操作系统自身的安全保护措施；第四，将数据以密文形式存储在数据库中。

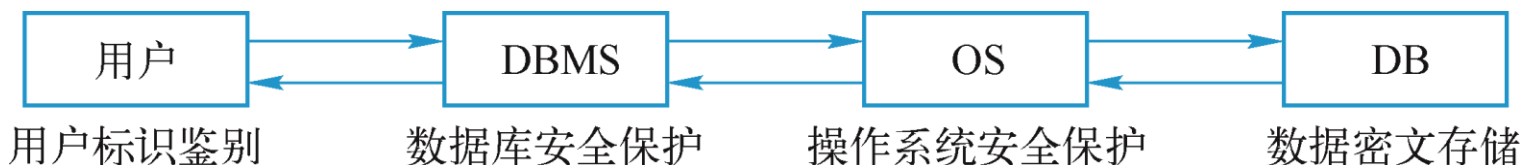
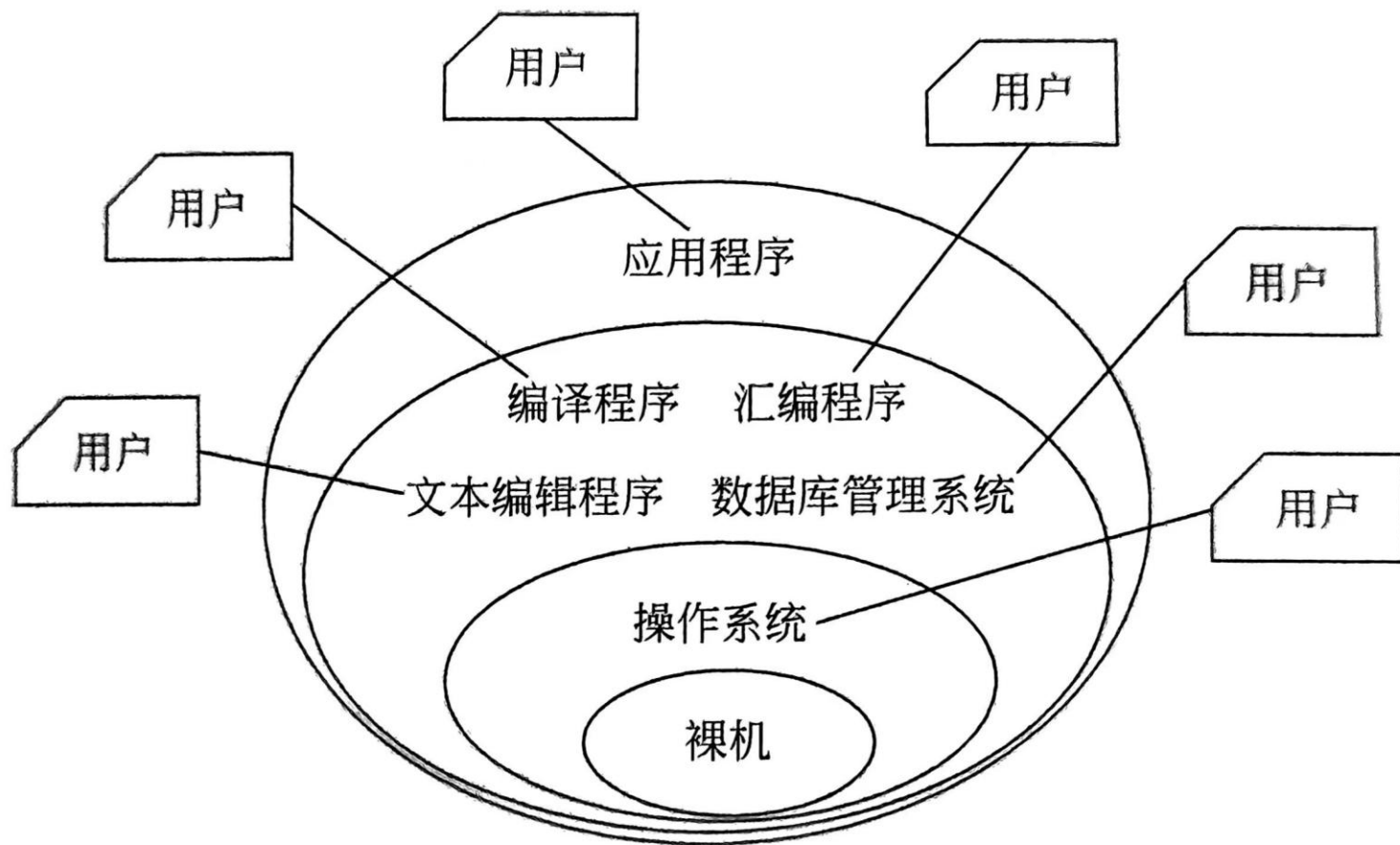


图 10-6 数据库安全防护模型



计算机系统的组成



10.3 数据库的安全防护技术

10.3.1 数据库安全防护及控制

2. 数据库安全性控制

常用方法有用户标识鉴别、存取控制、视图、审计、数据加密等。

用户标识鉴别：这是系统提供的最外层安全保护措施。用户标识由**用户名**和**用户标识号**组成，标识号在整个生命周期内是唯一的。常用方法有静态口令鉴别、动态口令鉴别、生物特征鉴别、智能卡鉴别等。

存取控制：这是 DBMS 的一种安全机制，由**用户权限定义**和**合法权限检查**两部分组成。存取控制包括自主存取控制 (Discretionary Access Control, DAC)、强制存取控制 (Mandatory Access Control, MAC)。



10.3 数据库的安全防护技术

10.3.1 数据库安全防护及控制

2. 数据库安全性控制

视图：把要保密的数据对无权存取这些数据的用户**隐藏**起来，对数据提供一定程度的**安全保护**。视图机制间接地实现支持存取谓词的用户权限定义。在不直接支持存取谓词的系统中，可以先建立视图，然后在视图上进一步定义存取权限。

审计：将用户对数据库的所有操作自动记录下来放入**审计日志**(Audit log)中，审计员利用审计日志可以**监控**数据库中的各种行为，**重现**事件，**找出**非法存取数据的人、时间和内容；通过日志分析，对潜在的威胁提前采取措施加以**防范**。**C2** 以上安全级别的 **DBMS**必须具有审计功能。

数据加密：数据加密是防止数据库中数据在存储和传输中失密的有效手段。加密方法有**存储加密**和**传输加密**。



10.3 数据库的安全防护技术

10.3.2 数据库的安全防护体系

1. 外围层的安全防护

1) 操作系统安全：主要安全技术有操作系统安全策略、安全管理策略及数据安全等。

2) 服务器及应用服务器安全：采用防火墙技术、防病毒技术等技术，保证服务器安全，确保服务器免受病毒等非法入侵。

3) 传输安全：VPN技术；3种加密策略，包括链路加密、端点加密、节点加密。

4) 数据库管理系统安全



10.3 数据库的安全防护技术

10.3.2 数据库的安全防护体系

2. 核心层的安全防护

1) 数据库加密

数据加密是数据库安全的**核心问题**。为了防止非法用户利用网络协议、操作系统漏洞，绕过数据库的安全机制直接访问数据库文件，必须对其文件进行加密。与网络通讯中的流数据不同，在数据库中，一般记录长度较短，数据存储时间较长，相应的**密钥保存时间也由数据生命周期而定**。若在库内使用同一密钥，则保密性差；若不同记录使用不同密钥，则密钥多、管理复杂。因此应针对数据库的特点，选取相应的加密及密钥管理方法。对于数据库中的数据，操作时主要是针对数据的传输，这种使用方法决定了**不可能以整个数据库文件为单位进行加密**。符合检索条件的记录只是数据库文件中随机的一段，通常的加密方法无法从中间开始解密。

10.3 数据库的安全防护技术

10.3.2 数据库的安全防护体系

2. 核心层的安全防护

2) 数据分级控制

根据数据库安全性要求和存储数据的重要程度，应对不同安全要求的数据实行一定的**级别控制**。如为每一个数据对象都赋予一定的密级：公开级、秘密级、机密级、绝密级。对于不同权限的用户，系统也会定义相应的级别并加以控制。可通过 DBMS 建立**视图**，管理员也可根据查询数据的逻辑进行归纳，并将其查询权限授予指定用户。此种数据分类的操作单位为授权矩阵表中的一条记录的某个字段形式。数据分级作为一种简单的控制方法，其优点是数据库系统能执行“信息流控制”，可避免非法的信息流动。



10.3 数据库的安全防护技术

10.3.2 数据库的安全防护体系

2. 核心层的安全防护

3) 数据库的备份和恢复

数据库一旦遭受破坏，数据库的备份则是**最后一道保障**。建立严格的数据备份与恢复管理是保障网络数据库系统安全的有效手段。数据备份不仅要保证备份数据的完整性，而且要建立详细的备份数据档案。系统恢复时使用不完整或日期不正确的备份数据都会影响系统数据库的完整性，甚至导致严重后果。



10.3 数据库的安全防护技术

10.3.2 数据库的安全防护体系

2. 核心层的安全防护

4) 网络数据库的容灾系统

容灾就是为恢复数字资源和系统所提供的技术和设备的保证机制，其主要手段是**建立异地容灾中心**。一是保证受援中心**数字资源的完整性**，二是在完整数据的基础上**恢复系统**，数据备份是基础，如完全备份、增量备份或差异备份。对于数据量较小且重要性较低的一些资料文档性质的数据资源，可采取单点容灾的模式，主要是利用冗余硬件设备保护该网络环境内的某个服务器或是网络设备。以避免出现该点数据失效。另外，可选择互联网数据中心（Internet Data Center, IDC）数据托管服务来保障数据安全。如果要求容灾系统具有与主处理中心相当的原始数据采集能力和相应的预处理能力，则需要构建应用级容灾中心，此系统在发生灾难和主中心瘫痪时，能够保证数据安全及系统正常运行。



10.3 数据库的安全防护技术

10.3.3 数据库的安全策略和机制

1. SQL Server的安全策略

数据库的安全策略是指导信息安全的高级准则，即组织、管理、保护和处理敏感信息的法律、规章及方法的集合，**包括**安全管理策略和访问控制策略。**安全机制**是用来实现和执行各种安全策略的功能的集合，这些功能可以由硬件、软件或固件实现。

数据库管理员(DBA)的一项最重要任务是保证其业务数据的安全，可以利用 **SQL Server 2022**对大量庞杂的业务数据进行高效的管理和控制。**SQL Server 2022**提供了强大的安全机制保证数据库及数据的安全。其**安全性包括3个方面**，即管理规章制度方面的安全性、数据库服务器实体(物理)方面的安全性和数据库服务器逻辑方面的安全性。



10.3 数据库的安全防护技术

10.3.3 数据库的安全策略和机制

1. SQL Server的安全策略

SQL 服务器安全配置**涉及**用户账号及密码、审计系统、优先级模型和控制数据库目录的特别许可、内置式命令、脚本和编程语言、网络协议、补丁和服务包、数据库管理实用程序和开发工具。在设计数据库时，应考虑其安全机制，在安装时更要注意系统安全设置。

注意:在 **Web** 环境下,除了对 **SQL Server** 的文件系统、账号、密码等进行规划以外还应注意数据库端和应用系统的开发安全策略，最大限度保证**互联网环境**下的数据库安全。

10.3 数据库的安全防护技术

10.3.3 数据库的安全策略和机制

1. SQL Server的安全策略

(1) 管理sa密码

系统密码和数据库账号的密码安全是第一关口。

use master

select name, password from syslogins where password is null

设置 sa 密码的操作步骤：①在 SSMS（SQL Server Management Studio）中，展开服务器；②单击展开安全性，然后展开登录名；③右键单击 sa，然后选择“属性”命令；④在密码框中，输入新的密码。

(2) 采用安全帐号策略和Windows认证模式

由于 SQL Server 不能更改 sa 用户名称，也不能删除超级用户，因此，必须对此账号进行严格的保管，包括使用一个**非常健壮的密码**，**尽量不在数据库应用中**使用sa账号，只有当无法通过其他方法登录 SQL Server 时(如其他系统管理员不可用或忘记密码)才使用sa。建议 DBA 新建立一个拥有与sa一样权限的超级用户管理数据库。在建立与 SQL Serve的连接时，**启用Windows 认证模式**。



10.3 数据库的安全防护技术

10.3.3 数据库的安全策略和机制

1. SQL Server的安全策略

(3) 防火墙禁用SQL Server端口

SQL Server 的默认安装可监视 TCP 端口 1433 以及 UDP 端口 1434，配置的**防火墙**可**过滤**掉到达这些端口的数据包。而且，还应在防火墙上阻止与指定实例相关联的其他端口。

(4) 审核指向SQL Server的连接

SQL Server 可以记录事件信息，用于系统管理员的审查。**至少应记录失败的SQL Server连接尝试**，并定期查看此日志。尽可能不要将这些日志和数据文件保存在同一个硬盘上。

在 SQL Server Management Studio(简称 SSMS)中审核失败连接的**步骤**:①右键单击服务器，然后选择“属性”命令;②在安全性选项卡的登录审核中，单击失败的登录;③要使这个设置生效，必须停止并重新启动服务器。



10.3 数据库的安全防护技术

10.3.3 数据库的安全策略和机制

1. SQL Server的安全策略

(5) 管理扩展存储过程

改进存储过程，并慎重处理账号调用扩展存储过程的权限。有些系统的存储过程能很容易被利用来提升权限或进行破坏，所以应删除不必要的存储过程。若不需要扩展存储过程，应去掉 `xp_cmdshell`。

注意:检查其他扩展存储过程，在处理时应进行确认，以免造成误操作。

(6) 用视图和存储程序限制用户访问权限

使用视图和存储程序以分配给用户访问数据的权利，而不是让用户编写一些直接访问表格的特别查询语句。通过这种方式，无须在表格中将访问权利分配给用户。视图和存储程序也可限制查看的数据，如对于包含保密信息的员工表格，可建立一个省略工资栏的视图。

(7) 使用最安全的文件系统

NTFS 是最适合安装 **SQL Server** 的文件系统。



10.3 数据库的安全防护技术

10.3.3 数据库的安全策略和机制

1. SQL Server的安全策略

(8) 安装升级包

为了提高服务器安全性，最有效的方法是升级 **SQLServer** 和及时修复安全漏洞。

(9) 利用**MBSA**评估服务器安全性

基线安全性分析器(**MBSA**)是一个扫描多种**Microsoft** 产品的不安全配置的工具，可在**Microsoft** 网站免费下载。

(10) 其他安全策略

10.3 数据库的安全防护技术

10.3.3 数据库的安全策略和机制

2. SQL Server的安全机制

SQL Server具有权限层次安全机制，安全性管理可分为4个层次：

- ①操作系统级的安全性。
- ②SQL Server级的安全性。
- ③数据库级的安全性。
- ④数据库对象级的安全性。

2. SQL Server的安全机制

SQL Server具有权限层次安全机制，安全性管理可分为4个层次：

- ①操作系统级的安全性。
- ②SQL Server级的安全性。
- ③数据库级的安全性。
- ④数据库对象级的安全性。

- ## 2. SQL Server的安全机制
- SQL Server具有权限层次安全机制，安全性管理可分为4个层次：
- ①操作系统级的安全性。
 - ②SQL Server级的安全性。
 - ③数据库级的安全性。
 - ④数据库对象级的安全性。

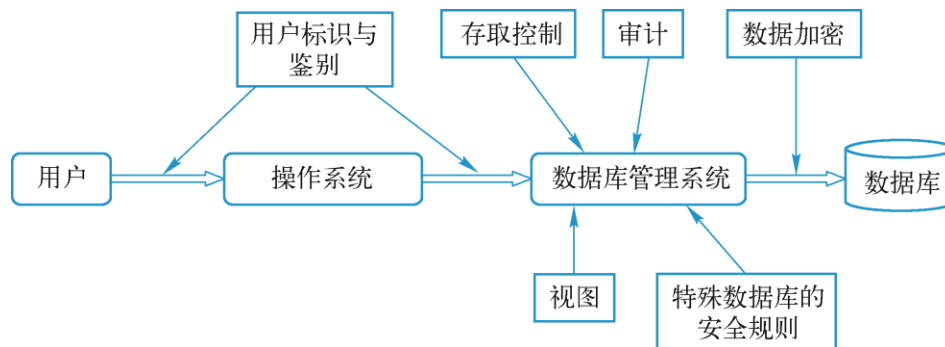


图10-7 SQL Server 的安全机制



10.3 数据库的安全防护技术

10.3.3 数据库的安全策略和机制

3. SQL Server安全性及合规管理

- ① 合规管理及认证
- ② 数据保护
- ③ 加密性能增强
- ④ 控制访问权限
- ⑤ 用户定义的服务器角色
- ⑥ 默认的组间架构
- ⑦ 内置的数据库身份验证
- ⑧ SharePoint激活路径
- ⑨ 对SQL Server所有版本的审核

SQL Server 2022 提供了增强的安全性和合规性，包括：集成证书管理、SQL 漏洞评估、SQL 数据发现和分类、始终使用安全区域加密等。



10.3 数据库的安全防护技术

10.3.3 数据库的安全策略和机制

4. 数据加密技术

SQL Server 将数据加密作为数据库的内在特性，提供了多层次的密钥和丰富的加密算法，用户还可以选择数据服务器管理密钥。其加密方法有：

- (1) 对称式加密
- (2) 非对称密钥加密
- (3) 数字证书

10.3.3 数据库的安全策略和机制

① 启用 SQL 服务。

③选择“事件选择”选项卡，选择显示的事件，进行筛选跟踪，如图10-8所示。

④ 分别用 **Windows** 身份验证和 **SQL Server** 身份验证登录，记录登录的事件，并查看分析结果，如图 10-9 所示。

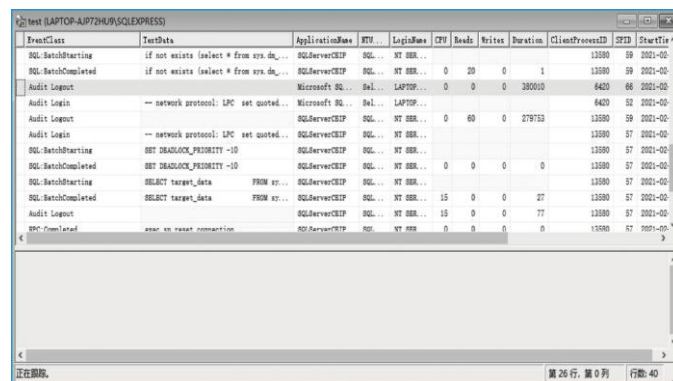


图 10-9 查看事件跟踪信息

10.4 数据库备份与恢复

10.4.1 数据库备份

案例10-5

2022 年初，知名开源库 `Faker.js` 和 `colors.js` 的作者 `Marak Squires` 主动恶意破坏了自己的项目，不仅“删库跑路”，还注入了导致程序死循环的恶意代码，使得全球大量使用该项目的个人与企业都受到了影响。

每年3月31日被定为世界备份日，提醒人们进行数据备份，以防数据丢失和宕机事件发生。建议实施 321 原则：服务器、本地存储、异地云存储三份副本，实现云中数据备份至本地、本地同步到云以及灾后快速恢复，最终确保业务连续性和数据资产安全。

10.4 数据库备份与恢复

10.4.1 数据库备份

数据库备份（Database Backup）是指为防止系统出现操作失误或系统故障导致数据丢失，而将数据库的全部或部分数据**复制**到其它存储介质的过程。

确定数据库备份策略需考虑的**3个因素**：

（1）备份内容与频率

①**备份内容**：备份时应及时对数据库中的**全部数据、表(结构)、数据库用户(包括用户和用户操作权)及用户定义的数据库对象**进行备份，并备份记录数据库的**变更日志**等。

②**备份频率**：主要由数据库中数据内容的**重要程度**、对数据**恢复作用**的大小和**数据量**的大小确定，并考虑数据库的**事务类型(读写操作比重)**和**事故发生的频率**等。

10.4 数据库备份与恢复

10.4.1 数据库备份

(2) 备份技术

①**数据备份**：数据备份是将整个数据库复制到另一个磁盘进行保存的过程。当数据库遭到破坏时，可将复制的备份重新恢复并更新事务。数据备份可分为**静态备份和动态备份两种**。鉴于数据备份效率、数据存储空间等相关因素，数据备份可以考虑**完全备份与增量备份**两种方式。

②**撰写日志(更新记录)**：日志文件是**记录数据库更新操作**的文件。用于数据库恢复中**事务故障恢复和系统故障恢复**，当副本载入时将数据库恢复到备份结束时刻的正确状态，并可对故障系统中已完成的事务进行重做处理。

(3) 基本相关工具

①备份工具 ②日志工具 ③检查点工具

10.4 数据库备份与恢复

10.4.2 数据库恢复

数据库恢复 (Database Recovery) 指当数据库或数据遭到破坏时, 进行快速、准确恢复的过程。

(1) 恢复策略

①**事务故障恢复**: 事务在正常结束点前就意外终止运行的现象称为事务故障。利用**DBMS** 可自动完成其恢复, 主要利用**日志文件撤销故障事务**对数据库所进行的修改。

②**系统故障恢复**: 系统故障造成数据库状态不一致的要素包括: 事务没有结束但对数据库的更新可能已写入数据库; 已提交的事务对数据库的更新没完成(写入数据库), 可能仍然留在缓冲区中。恢复步骤是**撤销**故障发生时没完成的事务, 重新开始具体执行或实现事务。

③**介质故障恢复**: 这种故障会造成磁盘等介质上的物理数据库和日志文件被破坏, 同前两种故障相比, 介质故障是**最严重**的故障, 只能**利用备份重新恢复**。

10.4 数据库备份与恢复

10.4.2 数据库恢复

(2) 恢复方法

①**备份恢复**：数据库维护过程中，数据库管理员应定期对数据库进行备份，生成数据库正常状态的备份。一旦发生意外故障，即可及时利用备份进行恢复。

②**事务日志恢复**：利用事务日志文件可以恢复没有完成的非完整事务，直到事务开始时的状态为止，通常可由系统自动完成。

③**镜像技术**：镜像是指在不同设备上同时存储两个相同的数据库，一个称为主数据库，另一个称为镜像数据库。主数据库与镜像数据库互为镜像关系，两者中任何一个数据库的更新都会及时反映到另一个数据库中。

(3) 恢复管理器

恢复管理器是 **DBMS** 中的一个重要模块。当发生意外故障时，恢复管理器先将数据库恢复到一个正确的状态，再继续进行正常处理工作。可使用前面提到的方法进行数据库恢复。

10.5 本章小结

数据库安全技术对于整个信息系统的安全**极为重要**，**核心和关键**在于**数据资源的安全**。

本章概述了数据安全性、数据库安全性和数据库系统安全性的有关**概念**，数据库安全的主要威胁和隐患，数据库安全的**层次结构**。在此基础上介绍了数据库安全的特性，包括**安全性、完整性、并发控制和备份与恢复技术**等，同时，介绍了数据库的安全策略和机制。

后续内容主要介绍 **SQL Server 2022** 安全管理实验目的、要求和操作步骤。





10.6 实验10 SQL Server 2022安全实验

10.6.1 实验目的

- 1) 理解SQL Server 2022身份认证的模式
- 2) 掌握SQL Server 2022创建和管理登录用户的方法
- 3) 了解创建应用程序角色的具体过程和方法
- 4) 掌握管理用户权限的具体操作方法
- 5) 掌握 SQL Server 2022数据库备份及还原的方法

10.6.2 实验要求

- 1) 预备知识：掌握数据库原理的基础知识，具有 SQL Server 实践操作的基本技能
- 2) 实验设备：安装有 SQL Server2022的计算机
- 3) 实验用时：2 学时

10.6 实验10 SQL Server 2022安全实验

10.6.3 实验内容及步骤

1. SQL Server2022验证模式

- 1) 打开 SSMS 窗口，选择一种身份验证模式，建立与服务器的连接。
- 2) 在“对象资源管理器”窗口中右击服务器名称，在弹出的快捷菜单中选择“属性”命令，弹出“服务器属性”对话框。
- 3) 在左侧“选择页”列表中选择“安全性”选项，打开如图 10-10 所示的安全性属性界面，在其中可以设置身份验证模式。

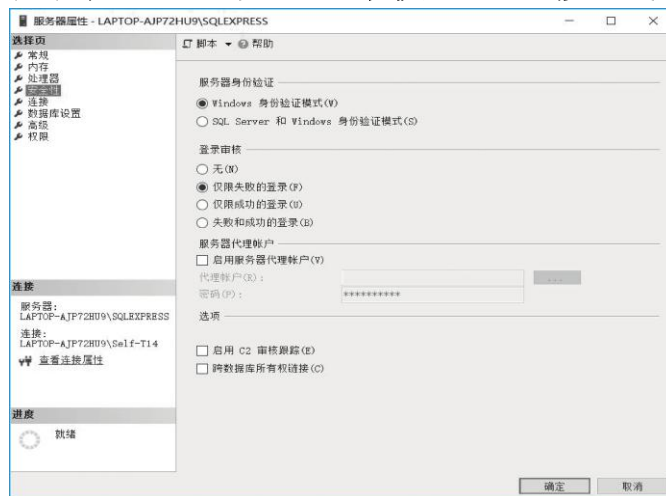


图10-10 安全性属性

10.6 实验10 SQL Server 2022安全实验

2. 管理服务器账号

(1) 查看服务器登录账号

打开“对象资源管理器”，可以查看当前服务器所有的登录账户。展开服务器，选择“安全性”选项，单击“登录名”节点后可列出所有的登录名，包含安装时默认设置的登录名，如图 10-11 所示。

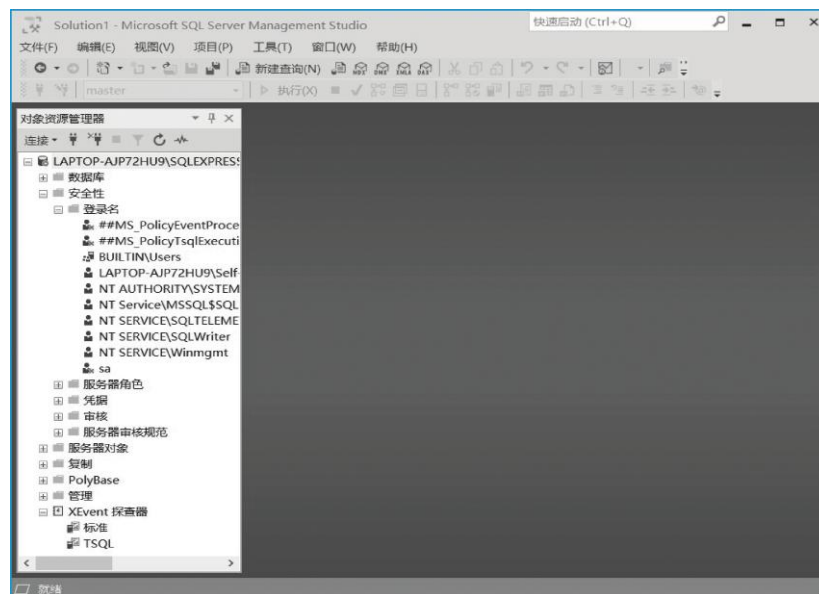


图10-11 对象资源管理器

10.6 实验10 SQL Server 2022安全实验

2. 管理服务器账号

(2) 创建SQL Server2022登录账户

- 1) 打开 SSMS, 展开服务器, 然后单击“安全性”节点。
- 2) 右击“登录名”节点, 从弹出的快捷菜单中选择“新建登录名”, 打开“登录名-新建”对话框。
- 3) 输入登录名“NewLogin”, 选择 SQL Server 身份认证并输入符合密码策略的密码, 默认数据库设置为“master”, 如图 10-12 所示。

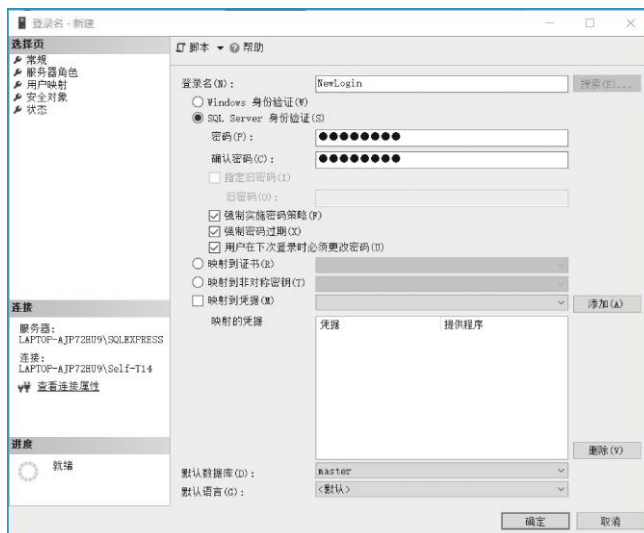


图10-12 新建登录名

10.6 实验10 SQL Server 2022安全实验

2. 管理服务器账号

(2) 创建SQL Server2022登录账户

4) 在“服务器角色”页面给该登录名选择一个固定的服务器角色，在“用户映射”页面选择该登录名映射的数据库并为之分配相应的数据库角色，如图 10-13 所示。

5) 在“安全对象”页面为该登录名配置具体的表级权限和列级权限。配置完成后，单击“确定”按钮返回。

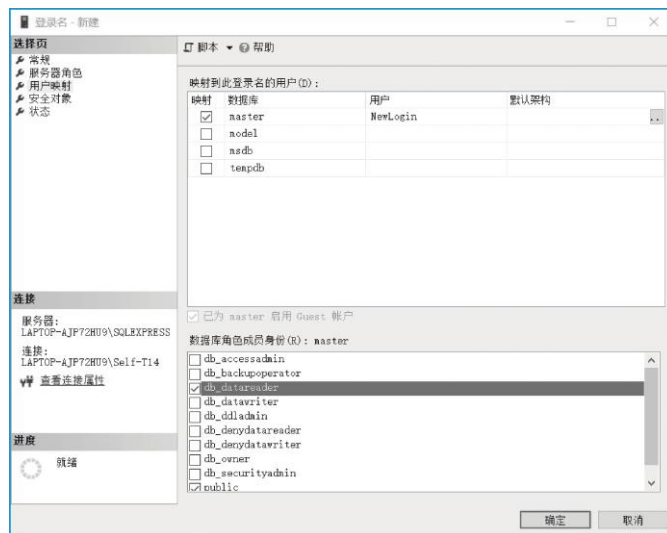


图10-13 服务器角色设置

10.6 实验10 SQL Server 2022安全实验

2. 管理服务器账号

(3) 修改/删除登录名

- 1) 在 SSMS 中，右键单击登录名，在弹出的快捷菜单中选择“属性”命令，打开“登录属性”对话框。该对话框格式与“新建登录”相同，用户可以修改登录信息，但不能修改身份认证模式。
- 2) 在 SSMS 中，右键单击登录名，在弹出的快捷菜单中选择“删除”命令，打开“删除对象”对话框，单击“确定”按钮可以删除选择的登录名。其中默认登录名 sa 不允许删除。

10.6 实验10 SQL Server 2022安全实验

3. 创建应用程序角色

- 1) 打开 SSMS，展开服务器，依次展开“数据库”→“系统数据库”→“master”→“安全性”→“角色”节点，右击“应用程序角色”，在弹出的快捷菜单中选择“新建应用程序角色”命令。
- 2) 在“角色名称”文本框中输入“Addole”，然后在“默认架构”文本框中输入 `dbo`，在“密码”和“确认密码”文本框中输入相应的密码，如图 10-14 所示。
- 3) 在“安全对象”页面上单击“搜索”按钮，选择“特定对象”单选按钮，然后单击“确定”按钮。单击“对象类型”按钮，勾选“表”，单击“确定”按钮，然后单击“浏览”按钮，勾选“spt_fallback_db”表，最后单击“确定”按钮后返回。
- 4) 在 `spt_fallback_db` 显示权限列表中，启用“选择”，单击“授予”复选框，然后单击“确定”按钮。

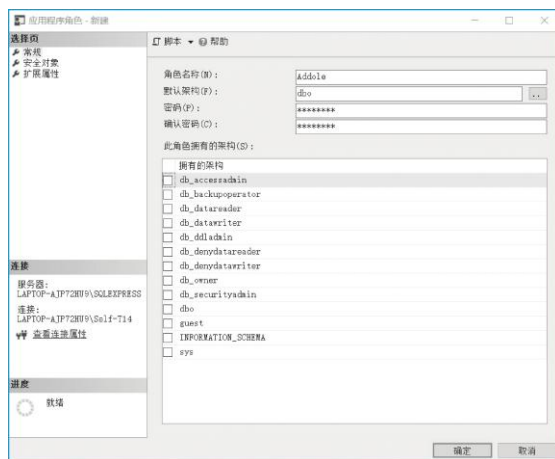


图10-14 新建应用程序角色

10.6 实验10 SQL Server 2022安全实验

4. 管理用户权限

- 1) 打开 SSMS, 展开服务器, 依次展开“数据库”→“系统数据库”→“master”→“安全性”→“用户”节点。
- 2) 右击“NewLogin”, 在弹出的快捷菜单中选择“属性”命令, 打开“数据库用户-NewLogin”对话框。
- 3) 选择“选择页”中的“安全对象”, 单击“权限”选项页面, 单击“搜索”按钮打开“添加对象”对话框, 并选择其中的“特定对象”, 单击“确定”按钮后打开“选择对象”对话框。
- 4) 单击“对象类型”按钮, 打开“选择对象类型”对话框, 选中“数据库”, 单击“确定”按钮后返回, 此时“浏览”按钮被激活。单击“浏览”按钮打开“查找对象”对话框。
- 5) 选中数据库 master, 一直单击“确定”按钮后返回“数据库用户属性”对话框, 如图 10-15 所示。此时数据库 master 及其对应的权限出现在对话框中, 可以通过勾选复选框的方式设置用户权限。

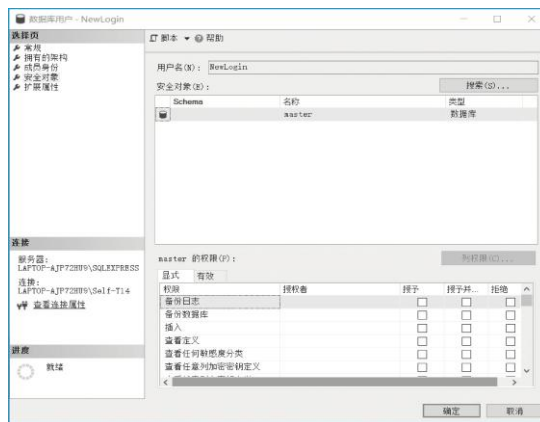


图10-15 管理用户权限

10.6 实验10 SQL Server 2022安全实验

5. 备份数据库

- 1) 管理备份设备。在备份一个数据库之前，需要先创建一个备份设备，比如网络站点、磁带、硬盘等，然后再去复制备份的数据库、事务日志、文件/文件组。
- 2) 备份数据库。打开 SSMS，右击需要备份的数据库，依次选择“任”→“备份”，打开“备份数据库”对话框，可以选择要备份的数据库和备份类型，如图 10-16 所示。

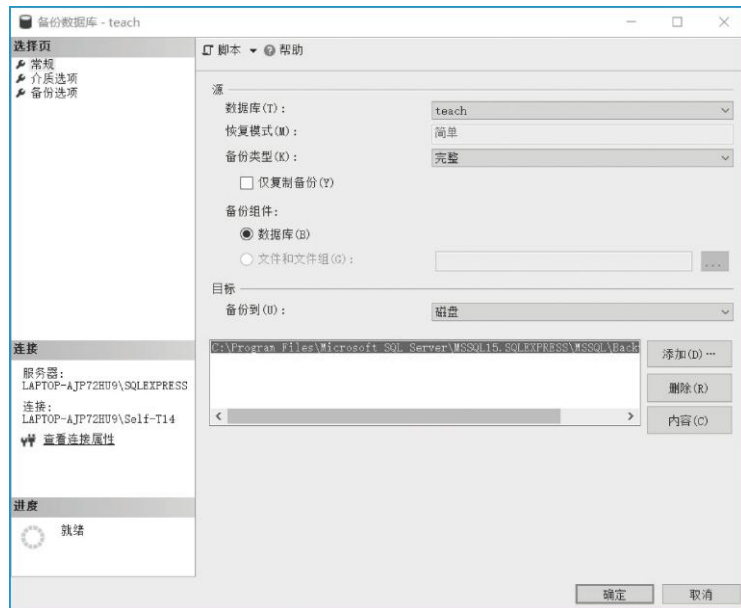


图10-16 备份数据库

10.6 实验10 SQL Server 2022安全实验

5. 备份数据库

3) 备份类型。完整备份将备份整个数据库的所有内容，包括事务和日志。差异备份只备份上次数据库备份后发生更改的数据部分。差异备份比完整备份小而且备份速度快，因此可以经常备份，以减少丢失数据的危险。

4) 备份目标。可备份在磁盘或 Azure 云上，默认为 SQL Server 2022 的安装路径，可通过“添加”或“删除”按钮对备份设备及路径进行修改，如图 10-17 所示。设置“介质选项”“备份选项”后，单击“确定”按钮进行备份。

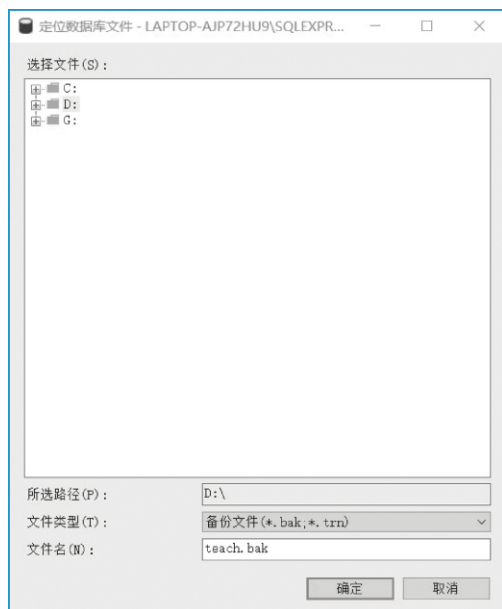


图10-17 更改备份路径

10.6 实验10 SQL Server 2022安全实验

6. 还原数据库

- 1) 还原数据库。打开 SSMS，右击“数据库”，在弹出的快捷菜单中选择“还原数据库”命令，打开“还原数据库”对话框，如图 10-18 所示。
- 2) 选择备份设备。在“源”选项组中选择“设备”选项，打开“选择备份设备”对话框，如图 10-19 所示。通过“添加”或“删除”按钮选择备份文件，然后单击“确定”按钮返回。选择的数据库的信息会回填，单击“确定”按钮即可开始还原。

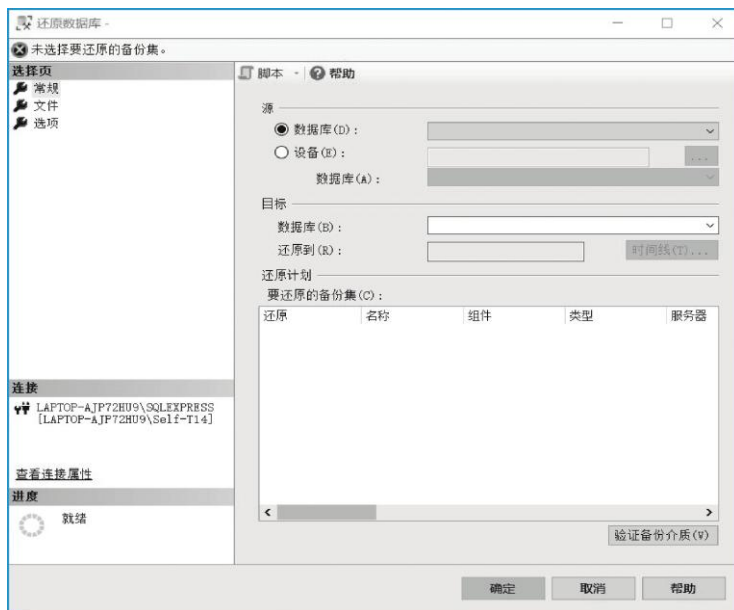


图10-18 还原数据库

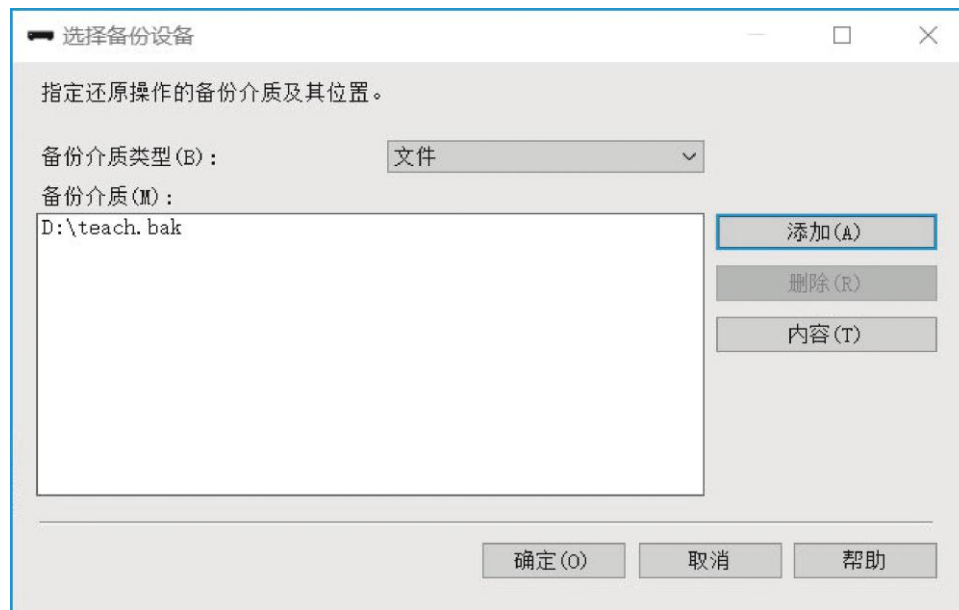


图10-19 选择备份设备

“十三五”国家重点出版规划
国家自然科学基金项目资助

上海市普通高校优秀教材奖
上海高校精品/优质在线课程

诚挚谢意！

网络安全技术及应用

国家智慧教育平台



(第5版, 微课版立体化)

